

Three police districts criticized for lack of processing security

Date: 17-05-2024

Decision

Public Authorities

Criticism

Supervision / self-management case

Processing Security

Logging

Sensitive Information

The Data Protection Agency has concluded its supervision of the user management and control of user usage ("log control") of the police case management system POLSAS in three selected police districts. The Data Protection Agency found reason to express criticism in all three cases due to insufficient log control.

Journal number: 2023-813-0001.

BORNHOLM POLICE.

Summary

In 2021, the Data Protection Agency initiated written supervision of the user management and log control of the police case management system POLSAS by Nordjylland Police, Fyn Police, and Bornholm Police, as large amounts of personal data are processed in the system, including information about criminal matters. The choice of the three police districts was due to their varying sizes and their representation of a geographical spread.

The police districts' information about user management in POLSAS – i.e., the administration of access rights, including how access rights are granted and revoked – did not give the Data Protection Agency cause for comments.

Criticism of insufficient log control

However, the Data Protection Agency found reason to express criticism that the police districts' log control was not in accordance with the rules on processing security, as they had not implemented fixed procedures for ongoing log control (e.g., through random checks) to ensure that users only access information they have a work-related need to process. The police districts only checked the log in cases of specific suspicion of misuse.

It is the Data Protection Agency's opinion that the requirement for appropriate security will normally imply that the data controller continuously conducts random checks of the log to verify that users only access information they have a work-related need for. A specific risk assessment can form the basis for how and how often this control should be performed. However, it is the Agency's view that random checks every six months will often be an absolute minimum if there is broad access, where employees have access to many confidential or sensitive information and/or access to information about many individuals.

Data controllers may also consider establishing alarms (e.g., based on log data) that are automatically activated in the event of suspicious activity – and this can supplement or replace more randomly selected random checks.

Log control has an immediate corrective function, but another significant purpose of implementing log control is that it can have a preventive effect. Informing employees that log control is conducted on an ongoing basis can therefore be an effective means of reducing the risk of misuse of otherwise legitimate access rights.

Prevention of misuse of access rights should, in the Data Protection Agency's opinion, occur through a combination of awareness, including what constitutes legitimate/illegitimate access, systematic rights management, as well as logging and ongoing control of users' access in systems where personal data is processed. Additionally, the data controller must ensure effective enforcement of the rules.

In assessing the cases, the Data Protection Agency emphasized that POLSAS processes both ordinary, sensitive, and other protected personal data, and that virtually all employees in the police districts have access to POLSAS – and, as a starting point, also access to all cases and information in the system.

The Data Protection Agency also noted in connection with the supervision that: employers must comply with data protection regulations regarding the obligation to inform when implementing control measures such as log control. This means that employees must be clearly and unambiguously informed that registration and control are being conducted.

when there is joint data responsibility between two or more parties, it is important to prepare an agreement that clearly defines their respective responsibilities for compliance with the various obligations imposed on a data controller under the General Data Protection Regulation.

Two of the police districts expressed that the lack of implementation of random checks was due to a misunderstanding that such control was performed by the National Police.

The Data Protection Agency has informed the National Police about the supervisions and has noted in this context that the supervision assumes that it is ensured that proper log control is also implemented in the other police districts, if it has not already been done.

Decision

1. Written supervision of Bornholm Police

Bornholm Police was among the authorities that the Data Protection Agency selected for supervision in the summer of 2021 under the law on law enforcement[1]. The Data Protection Agency's supervision was a written supervision that focused on Bornholm Police's management of access rights in the police case management system POLSAS.

By letter dated June 11, 2021, the Data Protection Agency announced the supervision of Bornholm Police. In this context, the Data Protection Agency requested to be informed:

****1. Information on the data processed in POLSAS****

how Bornholm Police manages access rights
for users with access to Bornholm Police's POLSAS,
including how access rights are granted and
revoked

general policies and procedures for
access control, including policies for audits and
sampling for unauthorized access attempts.

Bornholm Police issued a statement on August 11, 2021.

Based on the statement, the Data Protection Agency requested
by letter dated October 26, 2021, that Bornholm Police
provide documentation for the control of
authorizations in POLSAS for the past year. Bornholm
Police subsequently submitted a supplementary statement
in the matter on November 10, 2021.

The Data Protection Agency requested on January 12 and February 21,
2024, that Bornholm Police inform whether the police district
had implemented additional log control regarding
employees' use of personal data,
including in the form of sampling control, after the issuance of the
statement on August 11, 2021. Bornholm Police
then submitted supplementary statements to
the Data Protection Agency on February 6, 2024, and February 28, 2024.

****2. Decision****

Bornholm Police's information on the administration of
access rights for users with access to
Bornholm Police's POLSAS, including how
access rights are granted and revoked, does not
give the Data Protection Agency cause for comments.
However, following the inspection, the Data Protection Agency finds
reason to conclude that Bornholm Police at
the time of the notification of the inspection had not

implemented fixed procedures for ongoing log control (e.g., through sampling control) to ensure that users only access information they have a work-related need for, as control of the log was only conducted in cases of specific suspicion of abuse.

The Data Protection Agency therefore finds grounds to express criticism that Bornholm Police's processing of personal data has not been carried out in accordance with Section 27 of the Law on Law Enforcement.

Below follows a detailed review of the information that has emerged regarding log control in connection with the inspection and a justification for the Data Protection Agency's decision to criticize the insufficient log control.

****3. Case Presentation****

In the statement of August 11, 2021, Bornholm Police stated, among other things, which information is processed in POLSAS. It is indicated, among other things, that POLSAS is used by all police districts in the country, and that it is generally used for recording, registration, and written processing of all criminal cases, administrative cases, investigative cases, and incidents. In practice, all employees in a police district will be assigned POLSAS access. As a general rule, all users with access to POLSAS have access to all cases and all information therein, including personal data. However, it is possible to restrict parts of the access to reports and documents. All relevant information related to the police's broad task performance must, as a general rule, be registered in POLSAS, and this will therefore include personal data in the form of personal identification numbers, information about family relations, criminal matters, and health-related information. Regarding log control, etc., Bornholm Police in the statement of August 11, 2021 referred to information from the National Police's IT Department, which states, among other things: "As far as audits, sampling, and follow-up on unauthorized access attempts are concerned, it can be stated that the police districts and the National Police's areas must maintain a local information security organization, ensure implementation of applicable security regulations, and handle local follow-up on information security. The National Police's IT Department, Security conducts the overall supervision of information security based on the attached inspection concept and conducts sampling controls using the police's central systems and carries out physical inspections in police districts in collaboration with

the National Police's data protection unit.

The National Police does not centrally conduct sampling using POLSAS, but the individual police districts have the opportunity to conduct local follow-up on usage, as the local POLSAS log is available to the districts for a limited time.

[...]

If a caseworker in a police district discovers or merely suspects that others have accessed the case in question, they have the option to request a log printout through their immediate supervisor. Log printouts in POLSAS are provided by the National Police's IT Department, Security."

Bornholm Police has stated in this context that the police district, upon suspicion of unauthorized access/opening of documents in a specific case in POLSAS, requests log extracts from the National Police.

Bornholm Police has further stated that it is clearly stated in the National Police's Security Handbook and guidance on register searches and use of personal data that employees in police districts may only search for and use information that is relevant to their specific case handling or function.

Regarding the follow-up questions about whether Bornholm Police has implemented additional log control over employees' use of personal data, including in the form of sampling control, after the issuance of the statement on August 11, 2021, Bornholm Police has stated in the statements of February 6 and February 28, 2024, that the police district has subsequently introduced sampling control of log data from POLSAS. The log control is described in an attached

****action card****, which came into effect on December 1, 2022.

The log control has been conducted since the beginning of 2023. Log control is generally carried out twice a year and includes a minimum of 10 cases, where individual reports are selected, and all accesses are checked. The cases are selected partly randomly, although it is aimed to include cases that may be of particular interest, for example, due to significant media exposure, the theme of the case, or the group of individuals involved.

Regarding information to employees about log control, Bornholm Police has stated that the National Police informs police employees about various forms of data control, including checks of accesses in various systems, and that the different forms of control are described on the police intranet under the section "Particularly about monitoring of employees." Bornholm Police also continuously informs about the various forms of control, including log control of accesses in POLSAS, at staff meetings.

Bornholm Police has also stated that there is still, as previously described, control of accesses when there is a specific reason for it, e.g., in cases of suspicion of accesses without sufficient official reason. Bornholm Police has stated regarding the original control (prior to 2023) that it included the circumstance that the police district does not have independent access to the system log, which can only be retrieved by the National Police – and since it was subsequently clarified that the National Police did not conduct such random checks, Bornholm Police initiated random checks with POLSAS on its own initiative as part of its shared data responsibility with the National Police for the processing of personal data in police systems.

It has also been stated that Bornholm Police additionally conducts random checks regarding employees' general awareness and knowledge of and compliance with centrally and locally

established information security policies, which occurs through physical inspections, checks of various drives, Outlook, etc., as well as through dialogue with approximately 10 employees annually.

****4. Justification for the Data Protection Authority's Decision****

The Data Protection Authority bases its decision on the information provided by Bornholm Police:

- that both ordinary and sensitive personal data and other protected personal data are processed in POLSAS
- that virtually all employees of Bornholm Police have been granted access to POLSAS, and that all users, as a rule, have access to all cases and all information therein, including personal data
- that Bornholm Police, at the time of the notification of the inspection, had not implemented fixed procedures for continuously conducting log control (e.g., through random checks) to ensure that users only access information they have a work-related need for, as checks of the log were only conducted in cases of specific suspicion of misuse.

It follows from Section 27 of the Law on Law Enforcement that the data controller must take appropriate technical and organizational measures to ensure a level of security that is appropriate to the risks associated with the data controller's processing of personal data.

Thus, the data controller has an obligation to identify the risks that the data controller's processing poses to the data subjects and to ensure that appropriate security measures are implemented to protect the data subjects against these risks.

The Data Protection Authority believes that the requirement for appropriate security will normally imply that the data controller continuously conducts random checks of the log to ensure that users only access information they have a work-related need for. A specific risk assessment can form the basis for how and how often this control should be conducted.

However, the Data Protection Authority believes that random checks every six months will often be an absolute minimum if there is broad access, where employees have access to many confidential or sensitive information and/or access to information about many individuals. It is thus not sufficient to only examine the log in cases of specific suspicion of misuse or in isolated potential misuse scenarios, e.g., as part of the police's handling of a case that has been mentioned in the media or similar. The Data Protection Authority notes in this context that the data controller may consider establishing alarms (e.g., based on log data) that are automatically activated in the event of suspicious activity – and that this can supplement or replace more randomly selected samples. Log control will in such cases primarily have a corrective function.

Another and significant purpose of implementing log control is that this measure can have a preventive function. Proper information to employees that log control is continuously conducted can thus be an effective means to reduce the likelihood of misuse of otherwise legitimate access rights.

Prevention of misuse of access rights should occur through a combination of awareness, including what constitutes justified/unjustified accesses, systematic rights management, logging, and ongoing control of users' accesses in systems that process personal data – as well as effective enforcement by the data controller.

Citizens should thus be able to trust that the police only process information about citizens for lawful purposes – and this places high demands on both the police and the individual employee.

The Data Protection Authority finds, therefore, that there are grounds for criticizing Bornholm Police – for not having implemented fixed procedures for continuously conducting log control (e.g., through random checks) at the time of the notification of the inspection.

to ensure that users only access information they have a work-related need for, as control of the log was only conducted in cases of specific suspicion of misuse – has not taken appropriate organizational and technical measures to ensure a security level that is commensurate with the risks associated with the municipality's processing of personal data, cf. Section 27 of the Law on Law Enforcement.

The Data Protection Agency has, however, noted that the Bornholm Police, following the initiation of the inspection by the Data Protection Agency in 2023, has implemented appropriate random checks of log information, and that awareness has been introduced regarding this. The Data Protection Agency has also noted that there is awareness, among other things, about what constitutes

legitimate/illegitimate access, as well as systematic rights management and logging of the use of personal data.

In connection with the inspection, the Data Protection Agency would like to generally remark that employers must observe the obligation to provide information in Articles 13 or 14 of the General Data Protection Regulation when implementing control measures. Employees must be informed in advance – in a clear and unambiguous manner – that registration/logging is taking place, and that the registration will be reviewed as part of an ongoing control, including random checks, to determine whether there is use contrary to the workplace's guidelines as well as in cases of suspicion thereof.

The Data Protection Agency further notes that it is important, when there is joint data responsibility between two or more parties, that it is clearly defined in an agreement or similar who is responsible for what. Joint data responsibility may arise, for example, if the parties jointly determine why personal data should be processed (the purpose), and how the information should be processed (the means).

[1] Act No. 410 of April 27, 2017, on the processing of personal data by law enforcement authorities with subsequent amendments.

[2] Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons in relation to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation).

[3] See further on this in the Data Protection Agency's guidance text on "Employee Monitoring" and "Guidance on Data Protection in Employment Relationships," which can be found on the Data Protection Agency's website.

[4] See the Data Protection Agency's further information on this in the Data Protection Agency's "Guidance on Data Controllers and Data Processors," which can be found on the Data Protection Agency's website.